

Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Работа №5

«Аудит паролей с помощью менеджера паролей»

Болорболд Аригуун

Группа: P3411

Выполнение

Создание и настройка менеджера паролей

Для настройки BitWarden сначала нужно было создать учетную запись, поэтому для этого указана почта (рисунок 1.

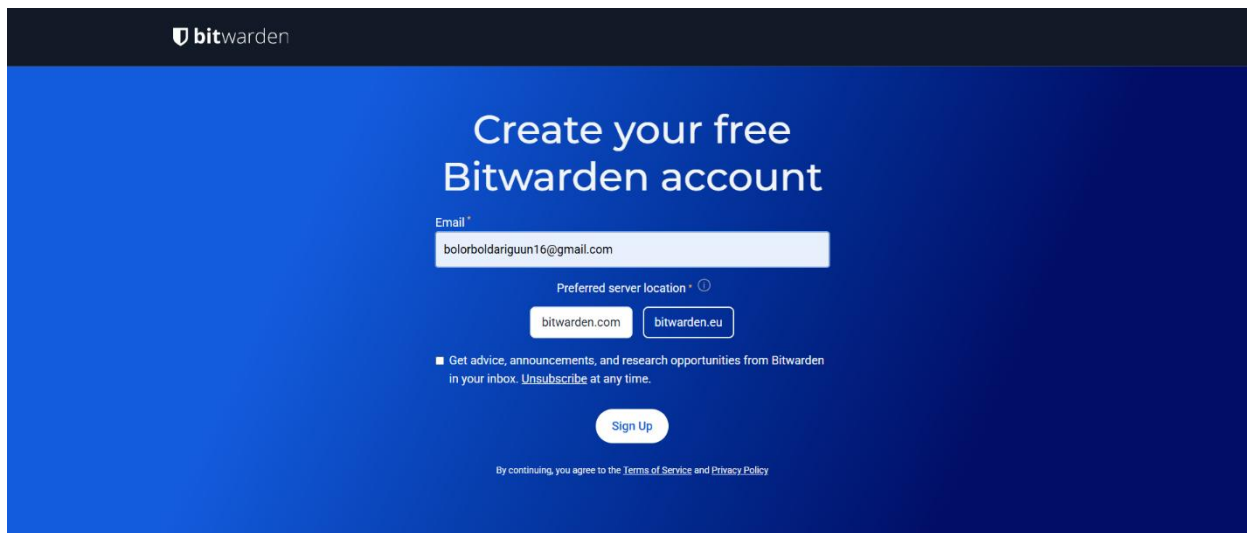


Рисунок 1 — Ввод электронной почты для создания учетной записи

После ввода почты на форму пришло письмо со ссылкой для активации учетной записи, как показано на рисунке 2.

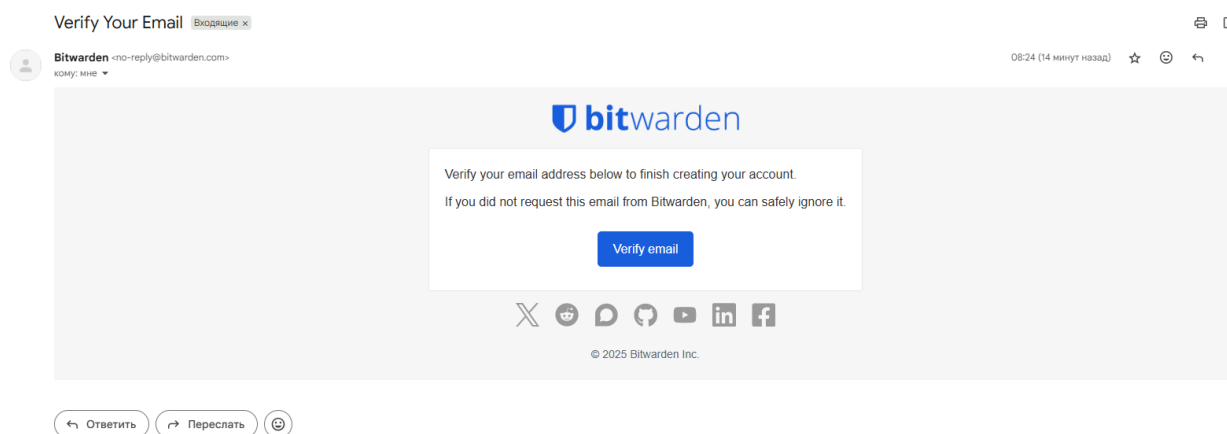


Рисунок 2 — Ввод хорошей мастер-пароли для создания учетной записи

Переходя по этой ссылке, появилась форма, куда нужно было вводить мастер-пароль. На рисунке 3 показано, как этот шаг был произведен.

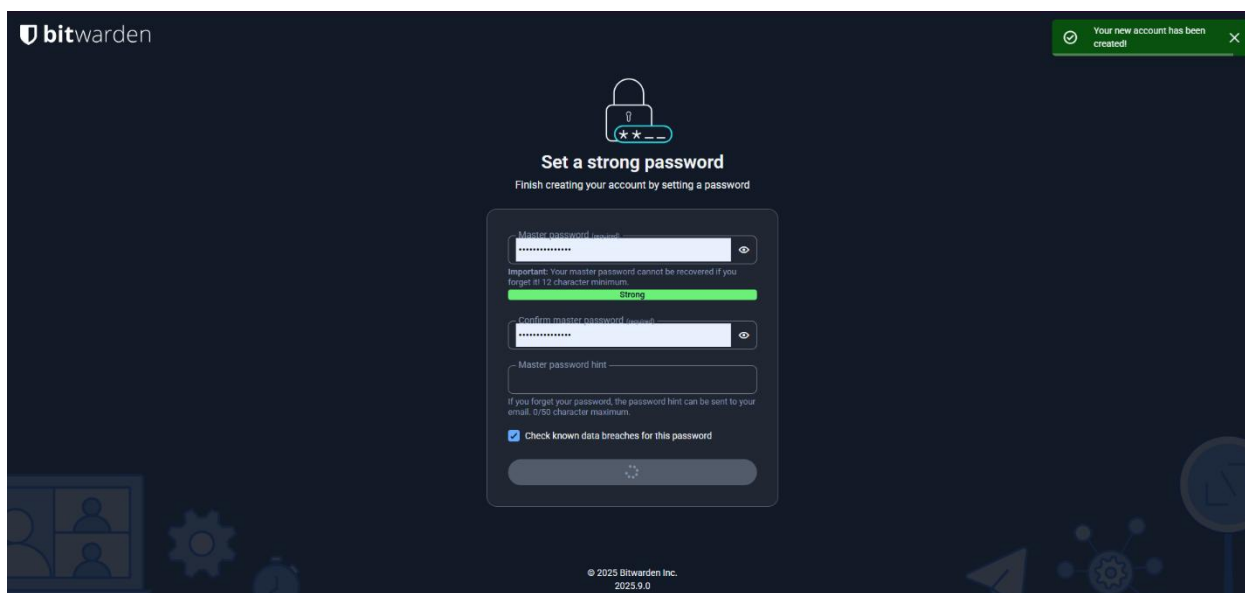


Рисунок 3 — Ввод хорошей мастер-пароли для создания учетной записи

После успешного создания учетной записи было произведено скачивание BitWarden. После выбора опции установка (как показано на рисунке 4) успешно произведено скачивание (рисунок 5).

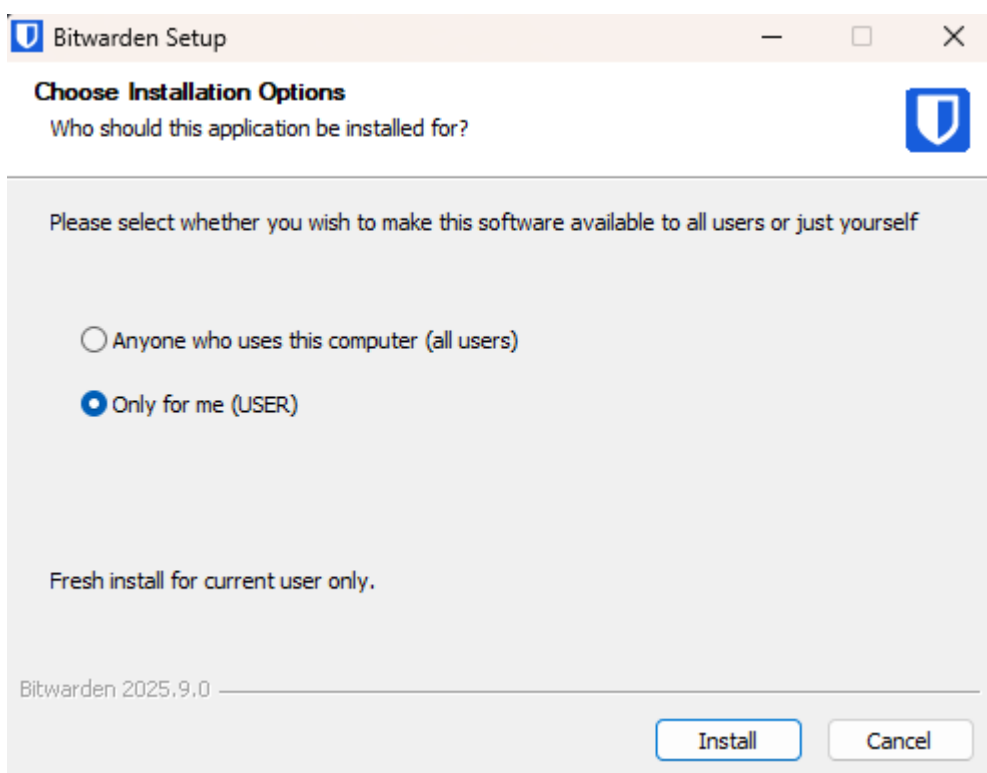


Рисунок 4 — Конфигурация режима установки BitWarden

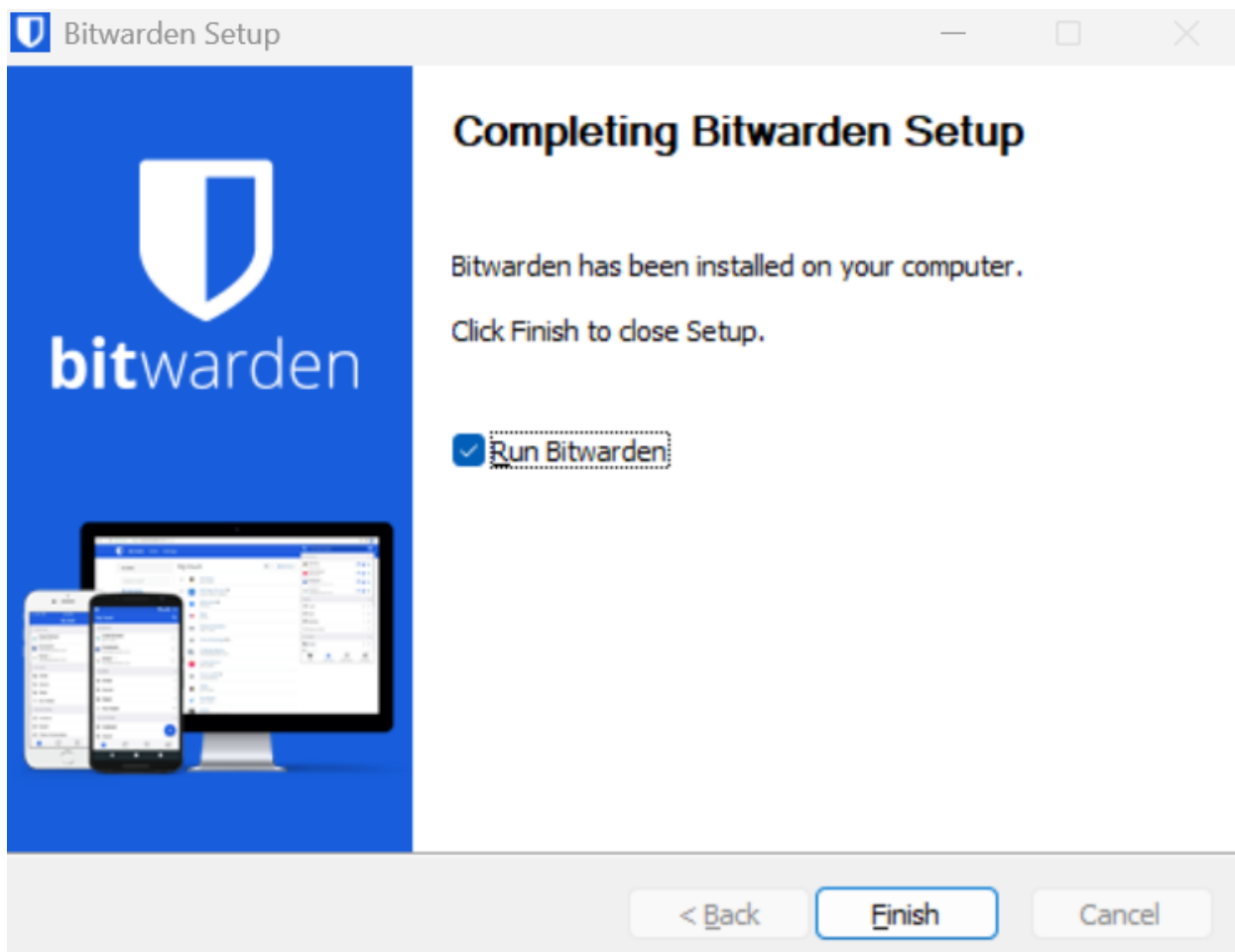


Рисунок 5 — Окончание установки BitWarden

И после последующей аутентификации с помощью данных учётной записи, созданного заранее, было полностью сконфигурирована BitWarden на персональном компьютере. Рисунок 6 — подтверждение.

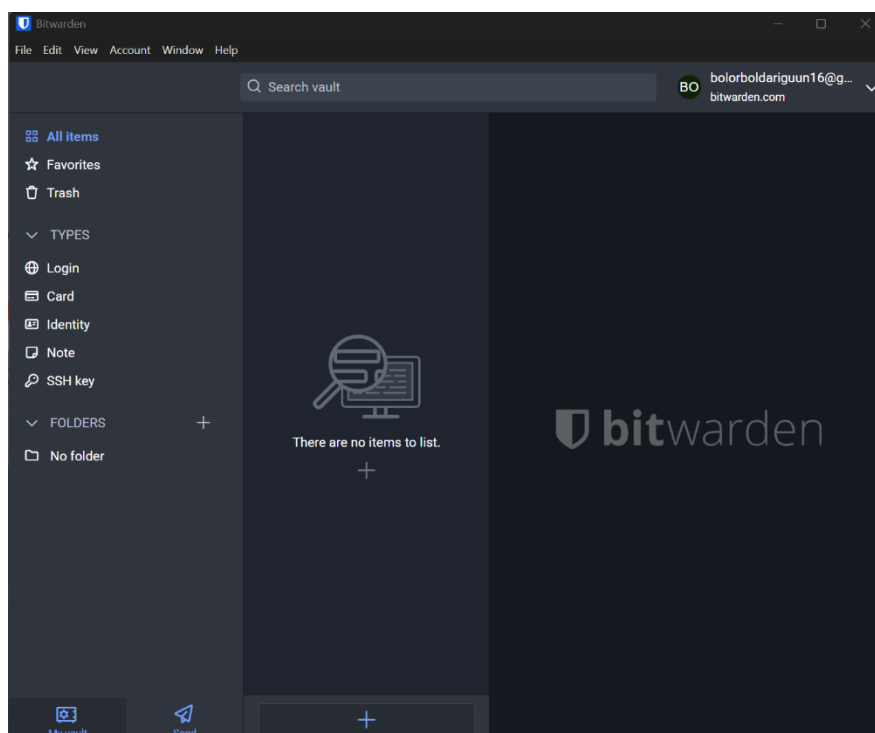


Рисунок 6 — настроенное приложение BitWarden на ПК

Аудит и замена паролей на надежные для 5 аккаунтов

Проведен анализ паролей в следующих платформах:

1) РЖД:

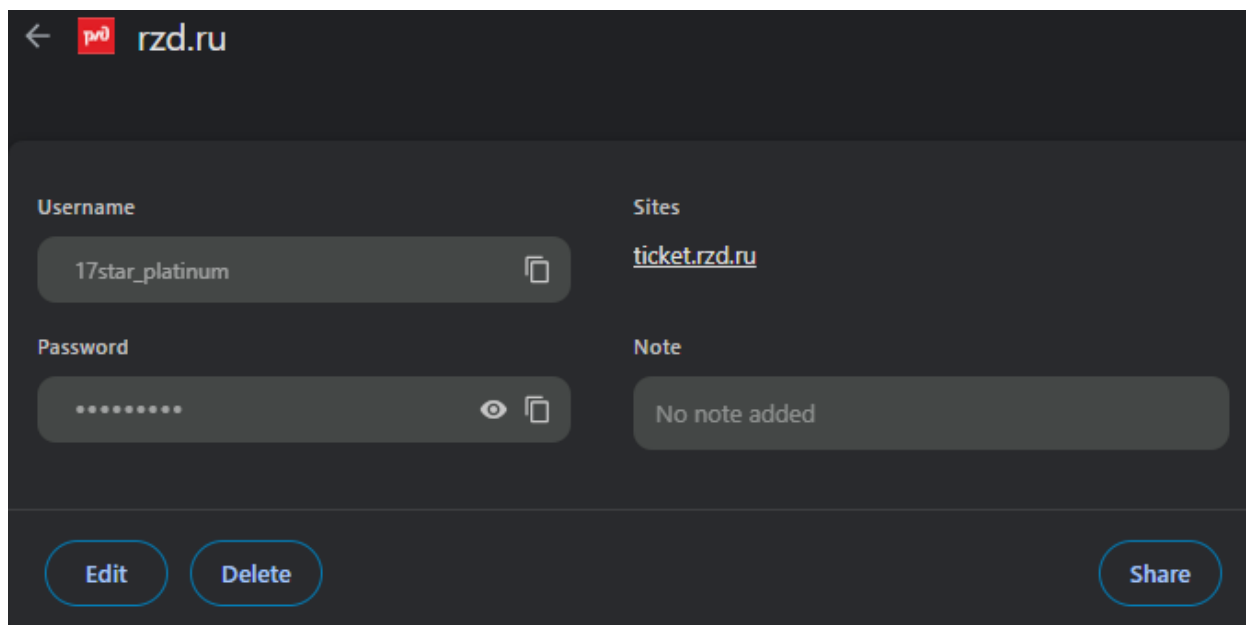


Рисунок 7 — Данные аутентификации для сайта ОАО «РЖД»

Пароль не самая лучшая с точки зрения стойкости, так как не был использован полный набор доступных символов, есть словарные слова как часть и длина пароля всего 9 символов.

Данные из этого сайта не были скомпрометированы. То, что были — показаны на рисунке 8.

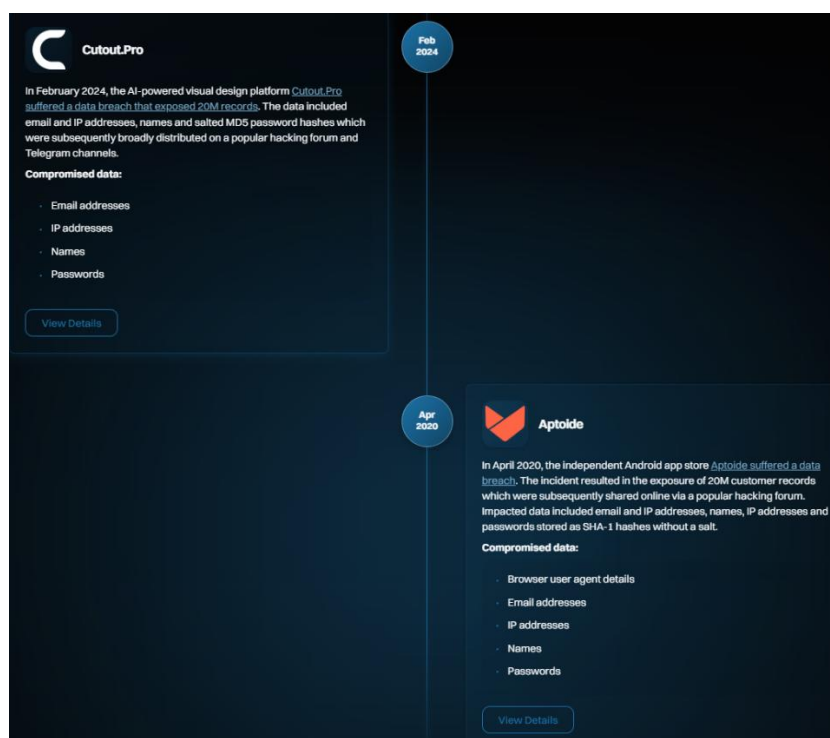
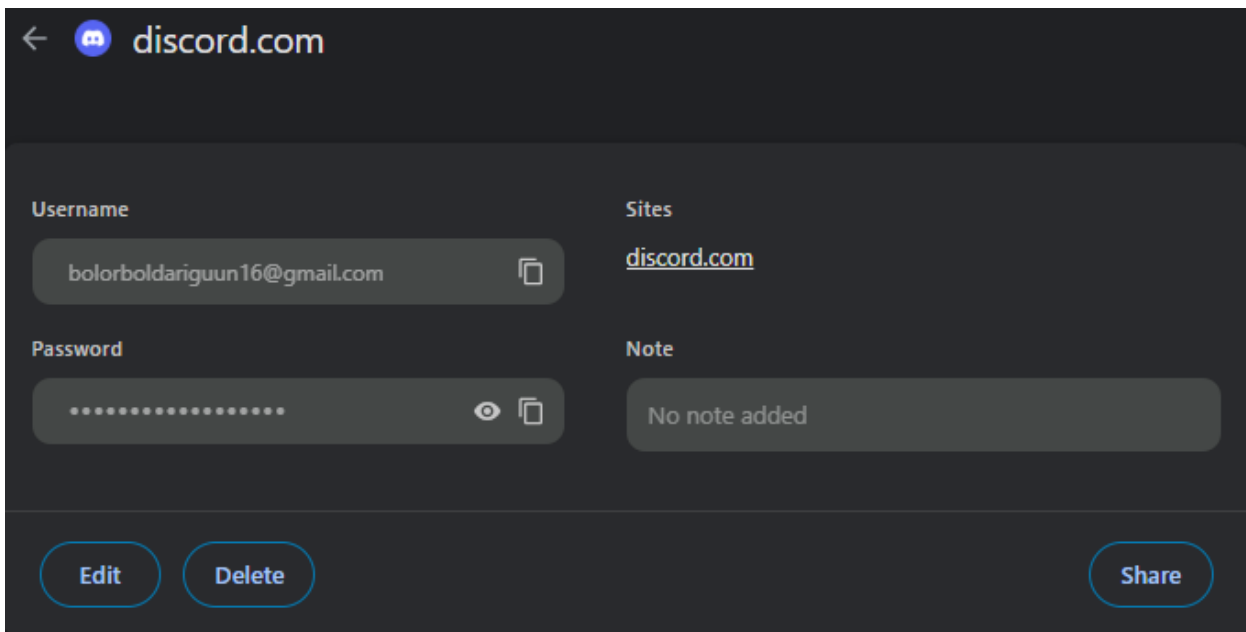


Рисунок 8 — Сайты с скомпрометированными данными

2) Discord:



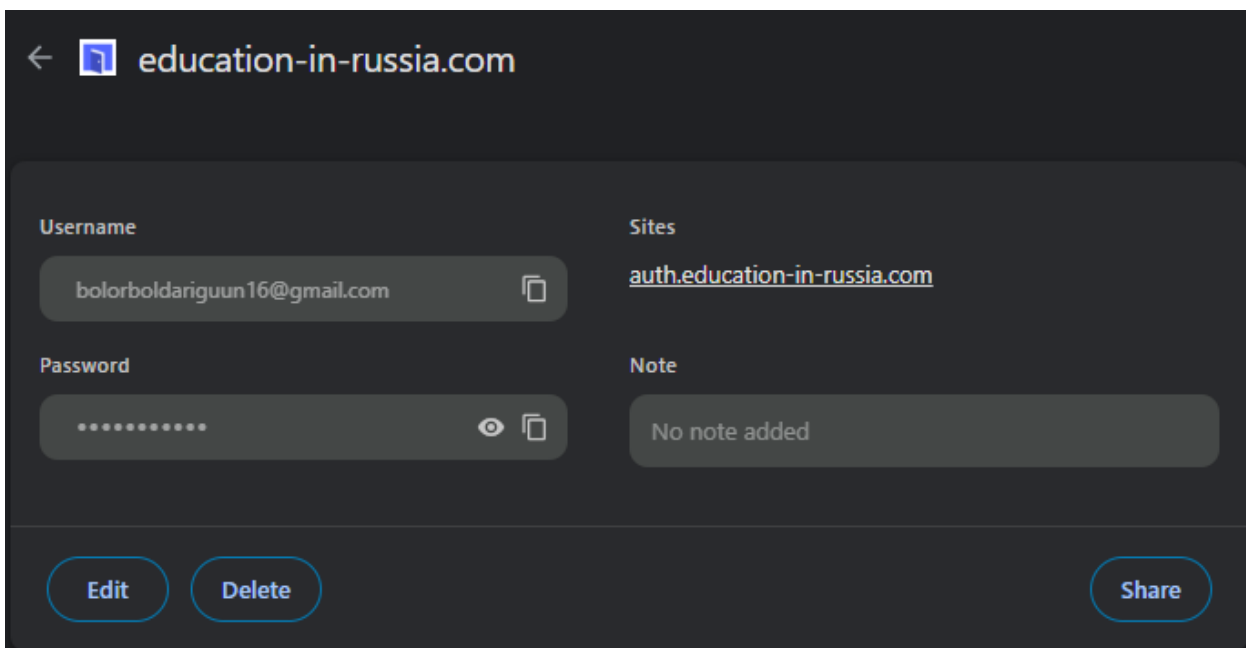
The screenshot shows a dark-themed interface for a password manager. At the top, there is a back arrow and the text "discord.com" next to a Discord logo. Below this, the form is divided into four sections: "Username" with the value "bolorboldariguun16@gmail.com" and a copy icon; "Sites" with the value "discord.com"; "Password" with a masked password "....." and icons for visibility and copy; and "Note" with the text "No note added". At the bottom, there are three buttons: "Edit", "Delete", and "Share".

Рисунок 9 — Данные аутентификации для платформы обмена сообщениями «Discord»

Пароль не самая лучшая с точки зрения стойкости, так как не был использован полный набор доступных символов и есть словарные слова как часть, но длина пароля уже адекватная — 18 символов.

Данные из этого сайта не были скомпрометированы.

3) Education In Russia:



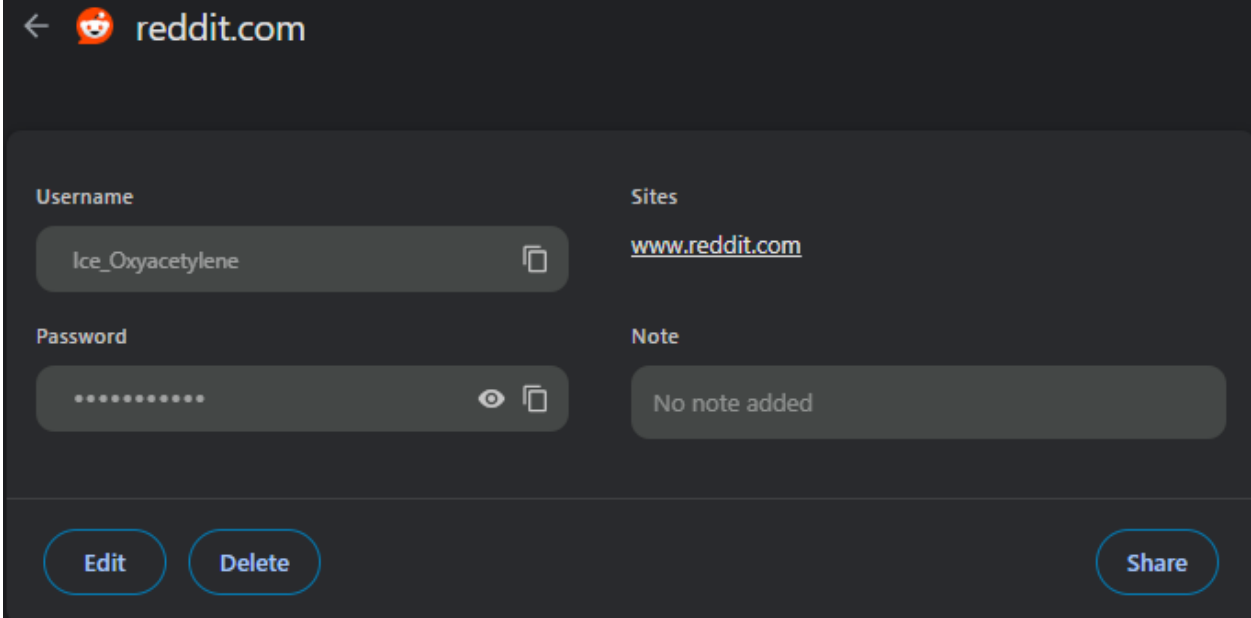
The screenshot shows a dark-themed interface for a password manager. At the top, there is a back arrow and the text "education-in-russia.com" next to a logo. Below this, the form is divided into four sections: "Username" with the value "bolorboldariguun16@gmail.com" and a copy icon; "Sites" with the value "auth.education-in-russia.com"; "Password" with a masked password "....." and icons for visibility and copy; and "Note" with the text "No note added". At the bottom, there are three buttons: "Edit", "Delete", and "Share".

Рисунок 10 — Данные аутентификации для платформы получение высшего образования в РФ «Education In Russia»

Пароль не самая лучшая с точки зрения стойкости, так как не был использован полный набор доступных символов, а также длина пароля является недостаточной — 11 символов. Однако не были использованы словарные слова и личные данные внутри пароля.

Данные из этого сайта не были скомпрометированы.

4) Reddit:



The screenshot displays a dark-themed interface for a password manager. At the top, there is a back arrow, a Reddit logo, and the text 'reddit.com'. Below this, the interface is divided into four main sections: 'Username' with the value 'Ice_Oxyacetylene' and a copy icon; 'Sites' with the value 'www.reddit.com'; 'Password' with a masked password '.....' and icons for visibility and copy; and 'Note' with the text 'No note added'. At the bottom, there are three buttons: 'Edit', 'Delete', and 'Share'.

Рисунок 11 — Данные аутентификации для платформы социальной сети «Reddit»

Пароль не самая лучшая с точки зрения стойкости, так как не был использован полный набор доступных символов, а также длина пароля является недостаточной — 13 символов. Не были использованы словарные слова и личные данные внутри пароля, но так как паролем является химическая формула определённого соединения, это требование все равно считается нарушенным.

Данные из этого сайта не были скомпрометированы.

5) Microsoft:

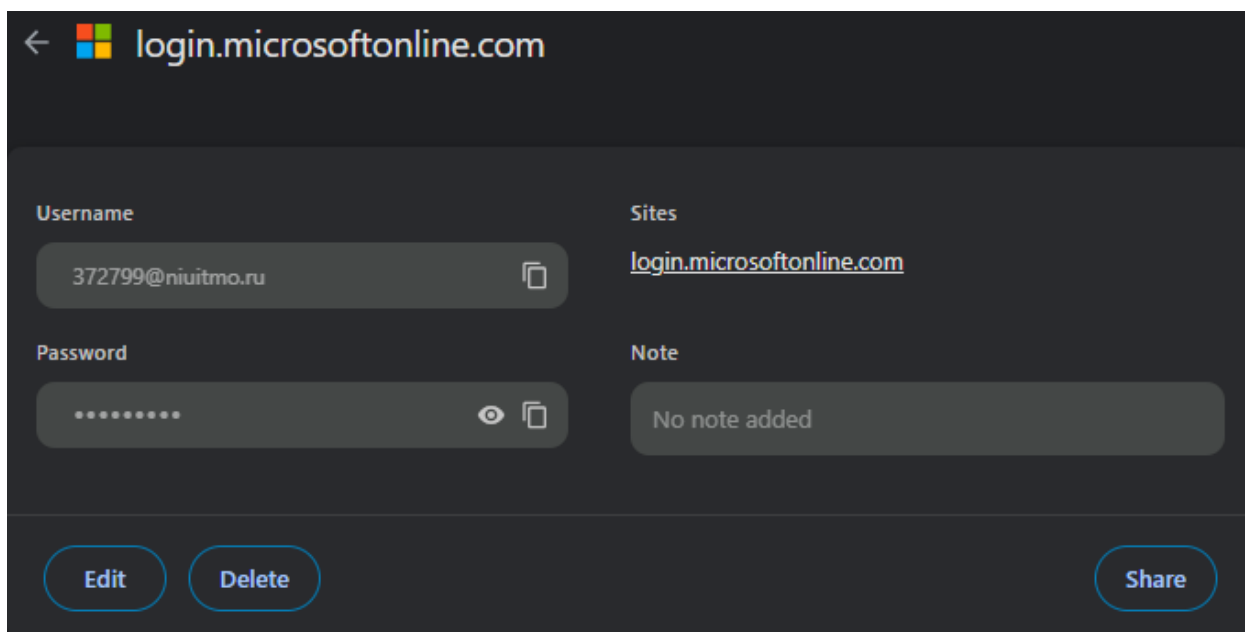


Рисунок 12 — Данные аутентификации для доступа к фирменным ПО и услугам компании «Microsoft»

Пароль не самая лучшая с точки зрения стойкости, так как не был использован полный набор доступных символов, есть словарные слова как часть и длина пароля всего 9 символов. Самая главная — этот пароль был использован и для сайта №1, что является грубым нарушением требований безопасности.

Данные из этого сайта не были скомпрометированы.

Для того, чтобы все пароли вышеперечисленных платформ были адекватными с точки зрения стойкости, требуется их полная замена на пароли, соответствующих следующим требованиям:

- Использование символов из максимально возможных видов. Сюда входят заглавные и строчные латинские буквы, цифры и специальные символы (“!”, “#”, “%”, “@”, “\$” и т.д.).
- Избежание использования пароля длиной менее 16 символов.
- Избежание переиспользования одного и того же пароля на разных платформах.
- Рандомизирование содержания пароля до максимальной степени. Не допускается использование словарных слов, публично известных фактов, личной информации (имя, день рождения, телефон и т.д.) и широкораспространённых последовательностей символов (123456789, qwerty и т.д.).
- Избежание использования пароля, обнаруженных в публичных утечках данных.

Производим этого на практике. Для этого в BitWarden надо добавить запись с данными аутентификации. Форма для этого показана на рисунке 13.

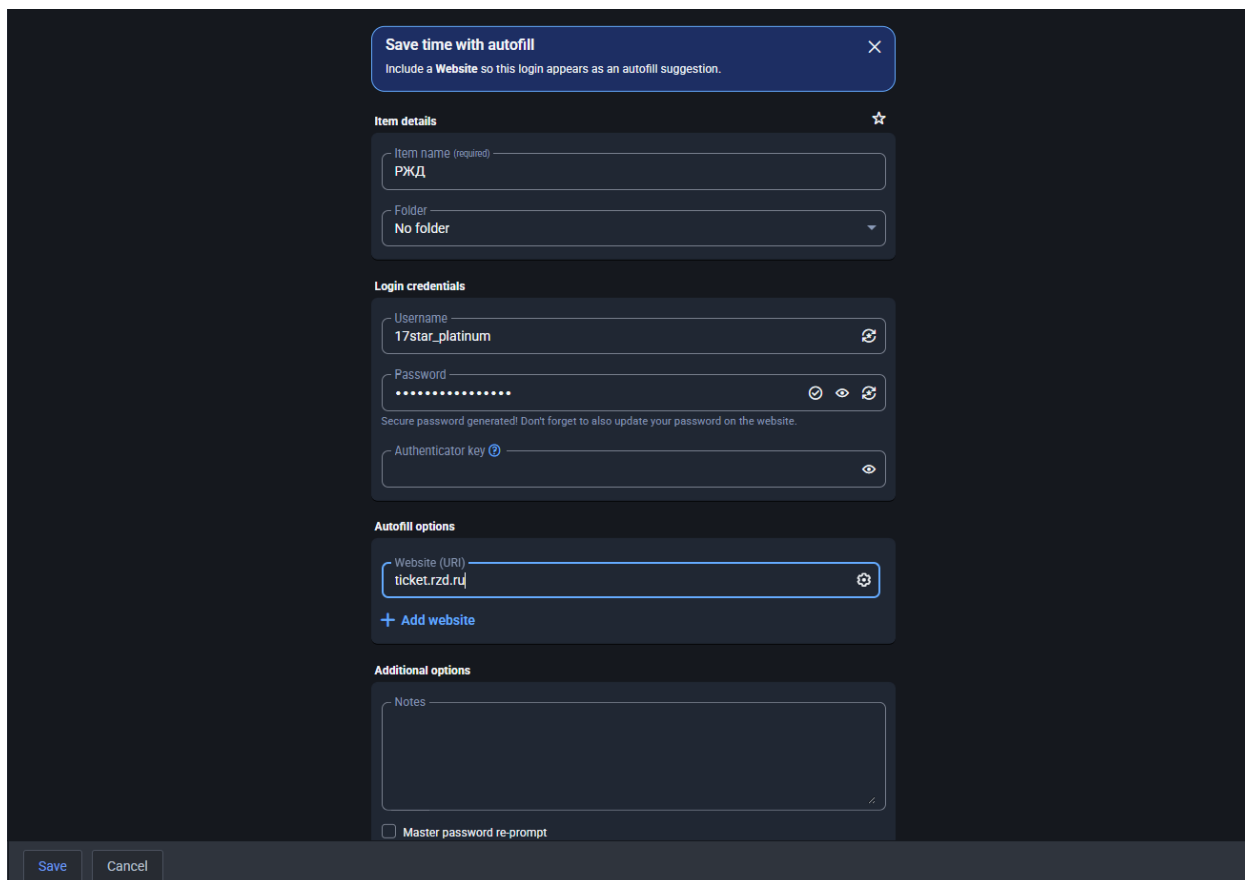
The image shows a dark-themed web form for adding a new login item in BitWarden. At the top, there is a blue banner with the text 'Save time with autofill' and a subtext 'Include a Website so this login appears as an autofill suggestion.' Below this, the form is organized into sections: 'Item details' with fields for 'Item name (required)' (containing 'РЖД') and 'Folder' (set to 'No folder'); 'Login credentials' with fields for 'Username' (containing '17star_platinum'), 'Password' (with a generated secure password and a note to update it on the website), and 'Authenticator key'; 'Autofill options' with a 'Website (URI)' field (containing 'ticket.rzd.ru') and an 'Add website' button; and 'Additional options' with a 'Notes' text area and a 'Master password re-prompt' checkbox. At the bottom left are 'Save' and 'Cancel' buttons.

Рисунок 13 — Форма для создания записи в «BitWarden»

Для того, чтобы произвести пароля, соответствующая вышеперечисленным требованиям, можно нажать на специальную кнопку генерации. Там возможно настраивать нового пароля под своим требованиям, как показано на рисунке 14.

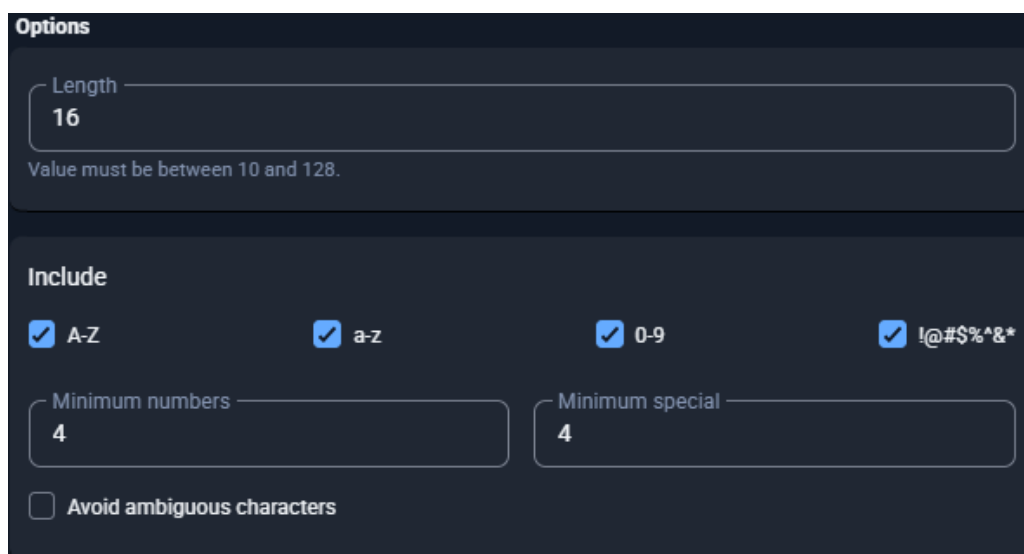
The image shows a 'Options' dialog for password generation. It features a 'Length' field set to '16' with a note 'Value must be between 10 and 128.' Below this is an 'Include' section with four checked checkboxes: 'A-Z', 'a-z', '0-9', and '!@#\$\$%*&*'. At the bottom, there are two fields: 'Minimum numbers' set to '4' and 'Minimum special' set to '4'. A checkbox for 'Avoid ambiguous characters' is present and unchecked.

Рисунок 14 — Форма с параметрами для создания нового пароля в «BitWarden»

Были произведены аналогичные шаги со всеми записями, итогов которых показана на рисунке 15.

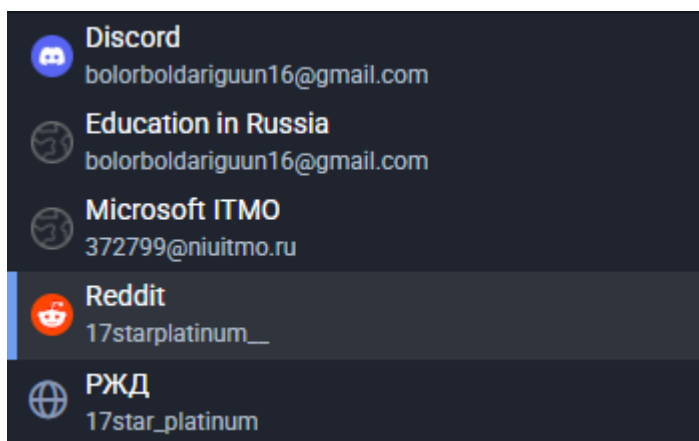


Рисунок 15 — записи в «BitWarden» аккаунтов с новыми паролями

Подключение 2FA через TOTP

Одного пароля обычно не хватит для безопасности. Надо ещё рассматривать сценарий, когда пароль каким-то образом оказалась у потенциального злоумышленника.

Для этого был придуман двухфакторная аутентификация, который дает доступ пользователю только после предоставления двух или более видов «доказательства механизма аутентификации». К ним обычно относят:

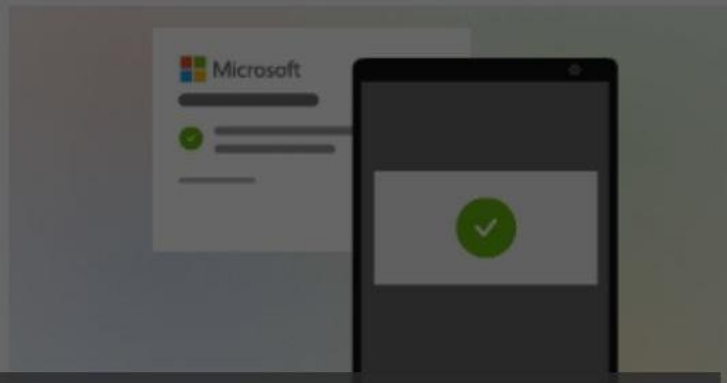
- Знание: пароля, ПИН-код, ключевая фраза и т.д.
- Владение: электронная или магнитная карта, флеш-память, токен и т.д.
- Свойство: биометрия (лицо, отпечаток пальца, ДНК и т.д.)

Для того, чтобы настроить 2FA на одном из учётных записей, использовано приложение Authenticator от Microsoft, и для удобства была выбрана учётная запись также из Microsoft.

Чтобы добавить запись в Authenticator, надо заново входить в учетную запись. После этого надо производить предоставление второго фактора — правильное число из данных.

Check Microsoft Authenticator

62 In your Authenticator app, tap the number shown on this page to sign in without a password.



New sign-in request for your Microsoft account.

I don't have access to my Microsoft Authenticator app

Tap the correct number to sign in, then enter your screen lock on the next screen.

372799@niuitmo.ru

From Russia on Android

68

80

62

DENY

APPROVE

[Terms of use](#)

[Privacy & cookies](#)

...

Рисунок 16 — 2FA для подключения TOTP к новому аккаунту
После его прохождения станет доступным запись, при нажатии которого появляется одноразовый код, который действует в течении срока.

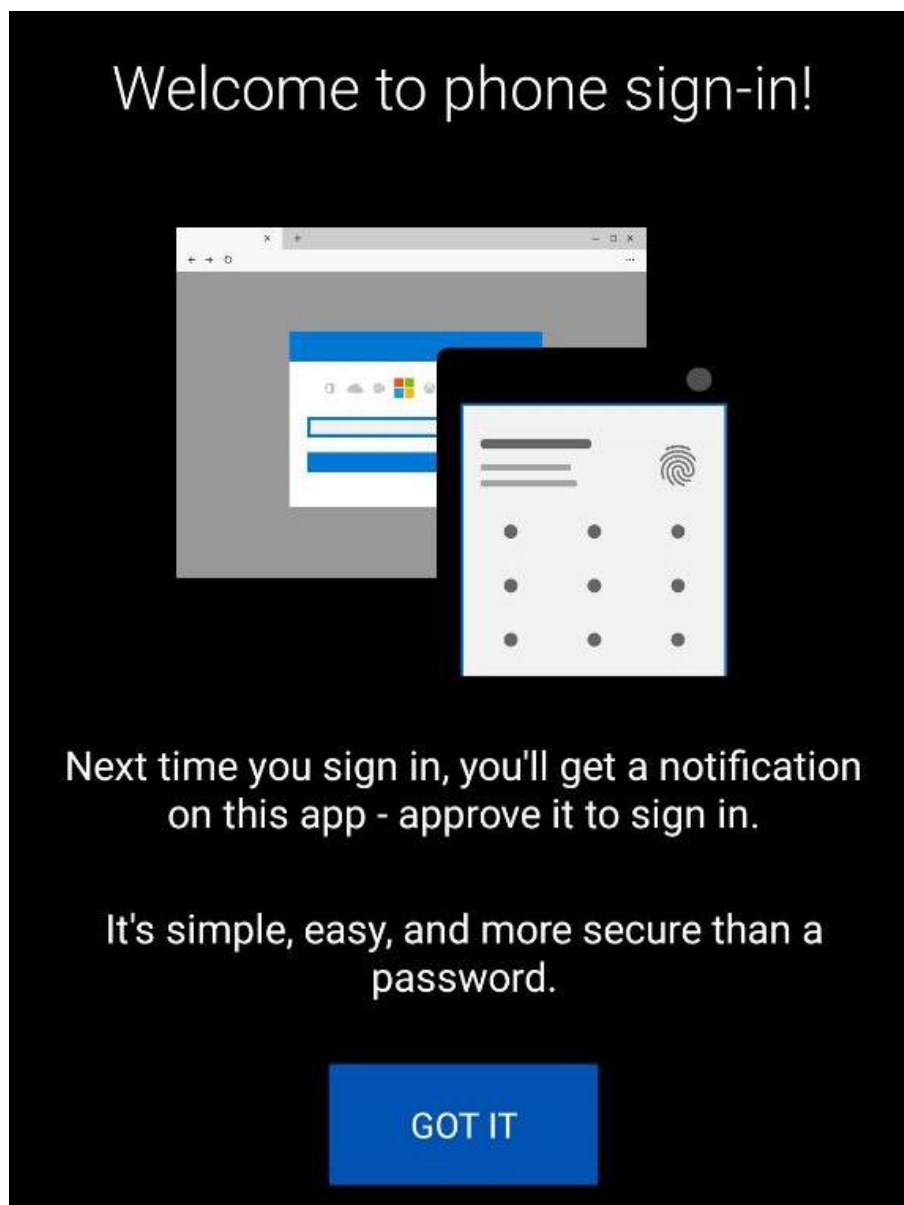


Рисунок 17 — Подтверждение подключения ТОТР к новому аккаунту с предложением мгновенного входа без пароля.

В результате этого при попытке логина от нового устройства спрашивается подтверждение через ТОТР, которого можно получить нажав на запись. Так как я не могу произвести непосредственный скриншот приложения (не разрешается из-за автоматической настройки приватности), внизу показан пример того, как выглядит запись с одноразовым кодом.

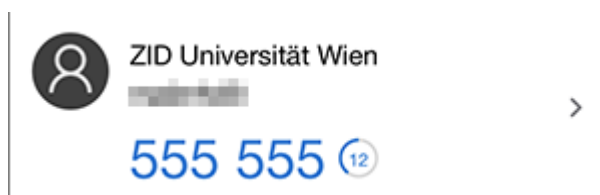


Рисунок 17 — Подтверждение подключения ТОТР к новому аккаунту с предложением мгновенного входа без пароля.